

PLANO INSTITUCIONAL DE SEGURANÇA, BACKUP E RECUPERAÇÃO DO SIG

Prefeitura Municipal
Ambiente: Supabase +
Vercel + GitHub
Versão 1.0 - 01 de
agosto de 2026

Documento de decisão e implantação. Não contém senhas, chaves, URLs privadas ou dados pessoais.

1. Decisão executiva

O SIG deve passar a ser um ativo institucional da Prefeitura, sem retirar do desenvolvedor a capacidade de operar, evoluir e atender o sistema. A solução recomendada é separar propriedade institucional de operação técnica, usar contas pessoais nominativas e manter dois proprietários institucionais em cada plataforma.

Princípio central

A Prefeitura controla a titularidade, pagamento, domínio, contas de recuperação e cópias de segurança. O desenvolvedor possui acesso administrativo nominativo, com MFA, auditável e revogável, nunca uma credencial compartilhada.

Resultados esperados

- Nenhuma pessoa isolada consegue bloquear a Prefeitura do Supabase, Vercel, GitHub, domínio/DNS ou dos backups.
- Falha, desligamento ou indisponibilidade do desenvolvedor não impede continuidade operacional.
- É possível restaurar dados, arquivos, esquema, políticas RLS, funções, triggers e infraestrutura em uma conta nova.
- Backups locais em SSD são cifrados, verificados, rotacionados e testados; não são simples cópias manuais sem validação.

Metas iniciais a aprovar

Indicador	Meta proposta	Observação
RPO - perda máxima de dados	Até 1 hora para incidente operacional; até 24 h como contingência local	Exige PITR no Supabase e exportação lógica diária.
RTO - retorno do serviço	4 h para restauração em projeto existente; 1 dia útil para reconstrução em contas novas	Validar em exercício trimestral.
Retenção	30 diários, 12 mensais, 7 anuais	Adequar à política de retenção e LGPD do Município.
Teste de restauração	Mensal parcial e trimestral completo	Backup não testado não é garantia de recuperação.

2. Escopo, riscos e premissas

O backup completo não é somente o banco PostgreSQL. No SIG, o repositório contém migrações SQL - inclusive RLS, RPCs, funções e triggers - e o Supabase também possui Auth e Storage. O plano cobre os cinco conjuntos abaixo.

Conjunto	Conteúdo que deve ser recuperável	Mecanismo
Dados PostgreSQL	Tabelas, dados, schemas, extensões, políticas RLS, grants, funções, views, índices, triggers e histórico de migração	PITR + dump lógico com schema e dados.
Arquivos	Objetos de todos os buckets do Supabase Storage e seus metadados	Cópia S3/rc1one + dump dos schemas storage.
Aplicação	Código Next.js, dependências travadas, scripts, migrações e documentação	GitHub institucional + mirror/exportação criptografada.
Configuração	Domínios, DNS, Vercel, variáveis por ambiente, configurações de Auth, provedores e integrações	Inventário versionado sem segredos + cofre institucional para valores.
Segredos e identidade	Chaves, credenciais de recuperação, MFA, e-mail institucional, tokens e responsáveis	Cofre de senhas institucional; não gravar segredos em Git nem no SSD sem cifragem.

Cenários tratados

- Exclusão acidental de dados, tabela, arquivo, usuário, bucket ou configuração.
- Ataque/ransomware, credencial comprometida, alteração maliciosa ou exposição de segredo.
- Indisponibilidade ou perda de uma conta individual do desenvolvedor ou de servidor local.
- Perda do projeto Supabase, da equipe Vercel, repositório GitHub ou até criação de contas novas do zero.
- Falha física, furto ou corrupção de um SSD de backup; por isso há rotação e cópia externa/offline.

Limite importante

Senhas de usuários, tokens secretos e algumas configurações geridas pela plataforma não devem ser presumidos recuperáveis por dump. A recuperação segura prevê rotação de chaves, redefinição de senhas e reconfiguração a partir do inventário e do cofre, não a reutilização cega de credenciais antigas.

3. Governança e acesso: Prefeitura proprietária, desenvolvedor operador

Criar e manter uma organização/equipe institucional em cada serviço, vinculada a caixa de e-mail corporativa e forma de pagamento da Prefeitura. Não usar contas pessoais como proprietárias finais. Todos os acessos devem ser pessoais, com MFA por aplicativo ou chave física; não compartilhar senhas, códigos MFA, e-mails de recuperação ou tokens.

Plataforma	Prefeitura	Desenvolvedor	Regra de proteção
Supabase	2 proprietários institucionais distintos; 1 administrador técnico municipal	Administrador ou owner somente se houver necessidade contratual	Proprietários institucionais guardam recuperação, cobrança e convite/revogação.
Vercel	2 owners institucionais; 1 responsável por faturamento	Member/Developer; Project Admin apenas no SIG	Owner municipal aprova mudança crítica, domínio e acesso a produção.
GitHub	Organização da Prefeitura; 2 owners institucionais	Maintainer/admin do repositório, sem ser único owner	Proteção de main, revisão obrigatória e 2FA para todos.
Domínio/DNS	Registro e DNS sob CNPJ/e-mail institucional; 2 contatos	Acesso técnico delegado quando necessário	Domínio é dependência crítica e deve constar do DR.
Cofre de segredos	2 custodiante municipais e trilha de auditoria	Acesso por item e tempo definido	Usar cofre corporativo com compartilhamento e recuperação administrativa.

Matriz operacional (RACI resumida)

Atividade	Responsável	Aprova	Evidência
Acessos e proprietários	TI municipal	Secretaria/TI dirigente	Lista trimestral de membros e MFA.
Mudança em produção	Desenvolvedor	TI municipal para alto impacto	PR, revisão e registro de implantação.
Backup automático/manual	Serviço de backup	TI municipal	Manifesto assinado, hash e resultado do teste.
Restauração	Desenvolvedor + TI municipal	Gestor de incidente	Ticket, autorização dupla e relatório pós-incidente.
Rotação de chaves	Desenvolvedor	TI municipal	Inventário atualizado; segredo anterior revogado.

Acesso de emergência - break glass

Manter duas contas institucionais de emergência, protegidas por MFA físico e guardadas por pessoas diferentes. Uso somente com dupla autorização, registro de motivo, expiração da sessão/tokens e rotação posterior. Não criar um 'usuário mestre' compartilhado.

4. Camadas de segurança a implantar

Prazo	Ação	Critério de aceite
0-7 dias	Transferir/organizar titularidade institucional; habilitar MFA e revisar membros	Há pelo menos 2 owners municipais por plataforma e nenhum acesso compartilhado.
0-7 dias	Inventariar domínio, DNS, plano, e-mails de recuperação, integrações e variáveis por ambiente	Inventário assinado, sem valores secretos em planilhas abertas.
0-14 dias	Ativar PITR do Supabase e confirmar plano/retenção; registrar RPO/RTO aprovados	Janela de recuperação documentada e teste de restauração em ambiente isolado.
0-21 dias	Implementar backup lógico, Storage, código e manifesto para destino institucional	Execução agendada produz cópia cifrada, hash e alerta de sucesso/falha.
0-30 dias	Implementar botão de backup manual com autorização, fila e auditoria	Não há segredo no navegador; a ação não bloqueia a interface e gera protocolo.
Contínuo	Revisar RLS, service_role, secrets, dependências, logs e permissões	Relatório mensal e exercícios de recuperação trimestrais.

Controles de desenvolvimento e produção

- Banco: RLS habilitada nas tabelas expostas, políticas testadas por perfil, funções SECURITY DEFINER revisadas e schema privado fora da API pública. O acesso service_role fica exclusivamente no servidor.
- Código: mudanças de esquema somente por migration SQL versionada; bloquear alteração direta não registrada no Dashboard. O repositório já possui pasta supabase/migrations, que passa a ser a fonte de verdade do esquema.
- GitHub: branch main protegida, pull request, revisão obrigatória, Actions com permissões mínimas, dependabot/code scanning conforme plano disponível e tokens de curta duração quando possível.
- Vercel: separar Production, Preview e Development; segredos de produção somente em Production, marcados como sensíveis; mínimo de pessoas que visualiza variáveis. Revisar logs para não vazarem dados.
- Auditoria: exportar periodicamente logs administrativos disponíveis e registrar em sistema municipal as mudanças de titularidade, domínios, secrets e restaurações.

5. Arquitetura de backup recomendada

Adotar a regra 3-2-1-1-0: ao menos 3 cópias, em 2 mídias/destinos, 1 fora do ambiente principal, 1 cópia offline ou imutável, e 0 erros verificados por teste. O SSD da Prefeitura é uma camada adicional, não substitui a cópia externa nem o PITR.

Camada	Frequência	Destino	Proteção e verificação
PITR Supabase	Contínuo	Supabase	Restauração até ponto temporal; confirmar plano, retenção e custo. Não cobre objetos apagados do Storage.
Dump PostgreSQL	Diário; sob demanda	Repositório de backup cifrado + SSD rotativo	Formato custom; schema+dados; hash SHA-256; teste de restore.
Storage	Diário incremental; semanal completo	Mesmo repositório + SSD rotativo	Sincronização S3/rclone, contagem/tamanho/hash de objetos e dump de metadados.
Código e migrações	A cada mudança + diário	GitHub institucional + mirror cifrado	Git bundle/mirror, tag de recuperação e verificação de clone.
Configuração e inventário	A cada alteração + mensal	Git privado sem segredos + cofre	Arquivo declarativo, lista de segredos (sem valores), hash e revisão humana.

Conteúdo do pacote de recuperação

- database-schema.dump e database-data.dump ou dump custom completo, incluindo public, auth quando tecnicamente suportado, storage e supabase_migrations; verificar privilégios especiais antes de restaurar em novo projeto.
- storage/ com todos os objetos dos buckets, e catálogo de inventário contendo bucket, caminho, tamanho, hash e data.
- repo.bundle ou mirror Git; migrations/; lockfile; versão do runtime; documentação do procedimento.
- manifest.json com versão, data/hora UTC, ID da execução, hashes, tamanho, status, origem, retenção e resultado de validação. Assinar o manifesto com chave separada do repositório de backup.
- runbook e inventário: nomes de projetos, regiões, domínio/DNS, provedores de Auth, integrações, chaves públicas, nomes de variáveis e responsável. Valores secretos apenas no cofre cifrado institucional.

Cifragem dos SSDs

Usar SSDs dedicados, cifrados integralmente (por exemplo, BitLocker com TPM+PIN ou solução corporativa equivalente). A chave de recuperação deve ficar no cofre institucional, com acesso dual-control. Etiquetar por rotação, nunca pelo conteúdo sensível, e desconectar após a cópia.

6. Operação de backup automático e para SSDs da Prefeitura

O serviço de backup deve executar fora do navegador e fora da Vercel, em máquina/servidor municipal ou provedor de automação administrado pela Prefeitura. Ele usa credenciais específicas de backup, de escopo mínimo, em cofre; não usa a `service_role` do app como chave universal.

Fluxo automático

Etapa	Como executar	Falha/alerta
1. Preparar	Ler credenciais de backup do cofre; criar diretório temporário protegido; travar execução concorrente.	Falha se cofre indisponível ou execução anterior pendente.
2. Banco	Executar dump lógico versionado (schema e dados) usando conexão de backup; registrar versão PostgreSQL e extensões.	Falha se tamanho anormal, dump incompleto ou hash ausente.
3. Storage	Listar e copiar objetos por API S3 compatível; gerar inventário e conferir quantidade/tamanho.	Falha se bucket/objeto não puder ser listado ou copiado.
4. Código/config	Atualizar mirror Git; exportar configuração declarativa e inventário de segredos sem valores.	Falha se repositório não tiver clone verificável.
5. Proteger	Comprimir quando adequado, cifrar, gerar hashes e manifesto assinado; enviar ao repositório remoto de backup.	Falha se assinatura, upload ou verificação remota não confirmar.
6. SSD	Em dia definido, operador conecta SSD cifrado; job copia pacote, verifica hash e solicita desconexão.	Não apagar SSD por rotina; marcar mídia como falha e alertar.
7. Relatar	Enviar status para e-mail/grupo institucional e painel de auditoria.	Alerta imediato no primeiro erro; escalonamento se >24 h sem backup válido.

Rotação física

- Manter no mínimo 3 SSDs cifrados: A em cofre da Prefeitura, B em local físico distinto controlado pela Prefeitura, C em rotação/offline. Preferir uma quarta cópia fora do prédio, conforme política municipal.
- Executar cópia semanal para o SSD conectado; cópia mensal marcada como retenção de longo prazo. Registrar cadeia de custódia: operador, data, mídia, hash e local de guarda.
- Não confiar em pendrive comum, pasta de rede desprotegida ou e-mail como destino de backup. Não manter o SSD permanentemente conectado.

7. Botão de backup manual: experiência segura de um clique

O requisito de 'um clique' deve ser entendido como uma solicitação simples ao usuário, não como uma rotina insegura no navegador. O botão cria uma execução de backup no serviço controlado. A cópia é feita em segundo plano, com registro e confirmação, sem expor chaves do banco ou do armazenamento ao cliente.

Componente	Implementação recomendada	Proteção
Tela administrativa	Página 'Continuidade e Backup' acessível apenas a perfil municipal autorizado e administrador técnico. Exibe último backup validado, destino, tamanho e testes.	RLS/RBAC, MFA, sessão recente e permissão específica BACKUP_REQUEST.
Botão	'Gerar backup agora' abre confirmação mostrando escopo e motivo; um clique confirmado gera protocolo e fila.	Rate limit, uma execução por vez, idempotência e dupla confirmação para produção.
API do app	Route Handler server-side autenticado valida perfil e encaminha job assinado ao orquestrador externo.	Nunca enviar connection string, token de cofre ou chave service_role ao browser.
Orquestrador	Worker institucional executa o mesmo pipeline automático, gera pacote, cifra, valida e grava manifesto.	Credencial de serviço mínima, rotação, logs imutáveis e rede restrita.
Resultado	UI recebe status assíncrono: enfileirado, executando, concluído, falhou; permite baixar somente manifesto e relatório, não o backup bruto.	Auditoria com usuário, horário, motivo, versão, hash e retenção.

Aprovação reforçada

Para backup manual comum, o solicitante pode iniciar o job. Para exportação que permita retirar dados pessoais do ambiente, exigir segundo aprovador municipal ou procedimento formal. O botão não deve oferecer download público do arquivo de dados.

Aceite funcional

- Usuário autorizado inicia a execução sem acessar segredos e recebe protocolo em até 30 segundos.
- A execução só é marcada concluída após hash, manifesto e teste de legibilidade; falha gera alerta e não substitui o último backup válido.
- Cada pedido aparece no log de auditoria, inclusive cancelamento e tentativa sem autorização.

8. Runbooks de recuperação

Toda restauração começa com declaração de incidente, congelamento de mudanças, preservação de evidências e decisão do gestor de incidente. Restaurar primeiro em ambiente isolado sempre que o incidente permitir; só então promover para produção. Após recuperação, rotacionar credenciais e investigar a causa.

Cenário	Resposta e recuperação	Validação antes de encerrar
Linha/arquivo apagado	Usar PITR ou backup mais próximo em projeto/ambiente de recuperação; extrair somente registros/objetos necessários e revisar conflitos.	Amostragem de dados, integridade referencial, permissões e aceite do setor dono.
Banco corrompido/alteração massiva	Escolher ponto PITR anterior ao evento; se não houver, restaurar dump lógico em projeto novo e redirecionar aplicação após testes.	Contagens, migrations, funções/triggers, RLS, relatórios e smoke test do app.
Storage excluído	Restaurar objetos a partir de cópia de Storage e conferir contra catálogo; restaurar metadados PostgreSQL compatíveis.	Contagem de objetos, URLs/ACLs, amostra de download e telas que usam anexos.
Conta do desenvolvedor indisponível	Owners institucionais removem/recriam acesso nominativo e continuam por código e runbook; nenhuma senha pessoal é necessária.	Membros, MFA, tokens e integrações revisados.
Ransomware/credencial vazada	Revogar sessões/tokens, pausar deploys, preservar logs, restaurar para ambiente limpo, rotacionar todos os segredos afetados.	Varredura de código/config, RLS, logs, acesso e teste de não recorrência.

Recuperação de desastre: novas contas Supabase, Vercel e GitHub

Ordem	Ação detalhada
1. Identidade	Criar/validar e-mails institucionais, MFA, dois owners por plataforma e acesso ao cofre. Recuperar domínio/DNS junto ao registrador institucional.
2. GitHub	Criar organização e repositório privado; importar mirror/bundle; proteger main; habilitar revisões; recriar secrets a partir do cofre. Secrets não recuperáveis devem ser regenerados.
3. Supabase	Criar organização/projeto na região aprovada; configurar acesso, Auth e Storage; aplicar migrations do repositório para reconstruir esquema, RLS, funções, views, grants e triggers; restaurar dados e objetos; conferir supabase_migrations.
4. Vercel	Criar equipe/projeto, vincular repositório e domínio; cadastrar variáveis por ambiente a partir do cofre; configurar integrações, cron, proteção e deploy.
5. Validar e cortar	Executar checklist de banco, login, permissões por perfil, anexos, fluxos críticos, logs e DNS; colocar em manutenção durante a troca; monitorar e registrar lições.

9. O que restaura e o que exige reconfiguração

Item	Origem de recuperação	Tratamento
Tabelas, triggers, funções, políticas RLS, views, índices	Migrations SQL versionadas + dump de schema	Aplicar migrations em projeto novo e comparar schema; dump é redundância e fonte de dados.
Dados de negócio	PITR ou dump lógico	Restaurar no ponto aprovado; validar integridade e retenção.
Arquivos de Storage	Cópia de objetos + metadados	Restaurar objetos e catálogo; lembrar que backups de banco não incluem arquivos do Storage.
Usuários Auth	Backup de banco quando aplicável + processo de reset	Validar suporte e dependências. Tratar senhas como não recuperáveis; forçar redefinição se necessário.
Variáveis Vercel e secrets GitHub	Cofre institucional e inventário	Recriar/rotacionar valores; nunca depender de exportação de valores secretos da plataforma.
Domínio, DNS e e-mail	Cadastro institucional + inventário	Reapontar DNS e validar SPF/DKIM/URLs de redirecionamento de Auth.
Deploys e logs históricos	Código/release notes; exportações de logs	Recriar deploy; histórico de logs pode não acompanhar transferência ou nova conta.

Ponto de controle técnico

Antes de declarar que o sistema pode ser reconstruído do zero, executar uma restauração trimestral em organização/projeto de teste recém-criados. O exercício deve provar que as migrations recompõem triggers, funções e RLS, que os objetos do Storage voltam e que os fluxos de login e perfis funcionam. O relatório do teste atualiza este plano.

Checklist pós-restauração

- Comparar número de tabelas, policies, funções, triggers, buckets e objetos com o manifesto do backup.
- Executar validação de migrations, smoke tests dos módulos críticos e testes com perfis sem privilégio para confirmar RLS.
- Testar login, primeiro acesso/redefinição de senha, upload/download, integrações de e-mail, rotas e relatórios.
- Rotacionar secrets, revisar logs e restaurar monitoramento/alertas antes de abrir o sistema ao público.

10. Plano de execução e evidências

Fase	Entregáveis	Responsáveis
A. Regularização institucional	Organizações/equipes, owners, MFA, cobrança, domínio/DNS, cofre e RACI aprovados.	TI municipal + gestor contratual.
B. Diagnóstico técnico	Inventário de tabelas/buckets, RLS, funções/triggers, variáveis, integrações, volumes e teste de migrações.	Desenvolvedor + TI municipal.
C. Backup automático	Worker, agendamento, destino cifrado, rotação SSD, manifesto, alertas e retenção.	Desenvolvedor implementa; TI municipal opera/valida.
D. Backup manual	Tela, autorização, API server-side, fila, auditoria e relatório de execução.	Desenvolvedor; aceite da Prefeitura.
E. Recuperação	Runbooks executáveis, ambiente de teste, exercício parcial e exercício de conta nova.	Equipe conjunta; gestor aprova.
F. Operação	Revisão mensal, teste trimestral, revisão semestral de acessos e anual de risco/retenção.	TI municipal, com apoio técnico.

Evidências que a Prefeitura deve exigir

- Ata de titularidade e lista de owners; evidência de MFA e de e-mails de recuperação institucionais.
- Inventário aprovado de ativos, variáveis por nome, integrações, domínio/DNS, responsáveis e cofre - sem expor valores secretos.
- Relatório de backup diário/SSD: ID, data, tamanho, hashes, assinatura, destino, retenção e resultado de restauração de teste.
- Relatório trimestral do teste de desastre em conta nova, com tempos reais (RTO/RPO), divergências e plano corretivo.
- Registro de mudanças em produção, revisão de acessos e rotações/revogações de credenciais.

Decisões necessárias antes da implantação

Decisão	Recomendação
Plano Supabase	Contratar PITR com retenção compatível ao RPO; avaliar tamanho/atividade antes do custo final.
Cofre	Escolher cofre corporativo com compartilhamento, recuperação e MFA; definir dois custodiante municipais.
Destino externo	Definir armazenamento externo cifrado e controlado pela Prefeitura para complementar SSDs offline.
Política LGPD	Validar base legal, retenção, acesso aos backups e descarte seguro com Encarregado/DPO e jurídico.
Janela de manutenção	Aprovar procedimento de parada e comunicação para restores de produção.

11. Referências oficiais e notas técnicas

As recomendações deste documento foram elaboradas a partir do estado conhecido do repositório SIG em 01/08/2026 e das fontes oficiais abaixo. Os detalhes de planos e funcionalidades devem ser revalidados na contratação, pois serviços em nuvem podem mudar.

Supabase

- Database Backups: backups diários, PITR, restauração e limitações; destaca que Storage não integra o backup de banco e que senhas de roles customizadas não são preservadas. <https://supabase.com/docs/guides/platform/backups>
- Backup and Restore using the CLI: dump/restauração lógica e preservação do histórico de migrations. <https://supabase.com/docs/guides/platform/migrating-within-supabase/backup-restore>
- Access Control: papéis Owner, Administrator, Developer e Read-Only; organização precisa manter ao menos um owner. <https://supabase.com/docs/guides/platform/access-control>
- Download Objects: cópia de objetos Storage por CLI/S3 e distinção entre objetos e metadados. <https://supabase.com/docs/guides/storage/management/download-objects>
- Database Migrations: migrations versionadas e sincronização de schema. <https://supabase.com/docs/guides/deployment/database-migrations>

Vercel e GitHub

- Vercel Access Roles: funções de team/project e responsabilidade de owners. <https://vercel.com/docs/rbac/access-roles>
- Vercel Environment Variables: variáveis cifradas em repouso, segregação por ambiente e visibilidade por quem tem acesso ao projeto. <https://vercel.com/docs/environment-variables>
- Vercel Transferring Projects: itens transferidos e não transferidos, incluindo observação sobre logs e integrações. <https://vercel.com/docs/projects/transferring-projects>
- GitHub: organização e proprietários possuem poderes administrativos; proteger essa função e ter mais de um owner é indispensável. <https://docs.github.com/en/enterprise-cloud@latest/organizations/managing-organization-settings>
- GitHub: restauração de repositório excluído por owner da organização, dentro das condições do serviço. <https://docs.github.com/en/repositories/creating-and-managing-repositories/restoring-a-deleted-repository>

Próximo passo recomendado

Realizar uma reunião de 60 a 90 minutos entre TI municipal, gestor responsável, DPO/jurídico e desenvolvedor para aprovar os responsáveis, RPO/RTO, retenção, cofre e destinos. Em seguida, executar as fases A e B antes de automatizar qualquer cópia de dados.

Classificação sugerida: uso interno institucional. Revisar ao menos anualmente e após incidente relevante.